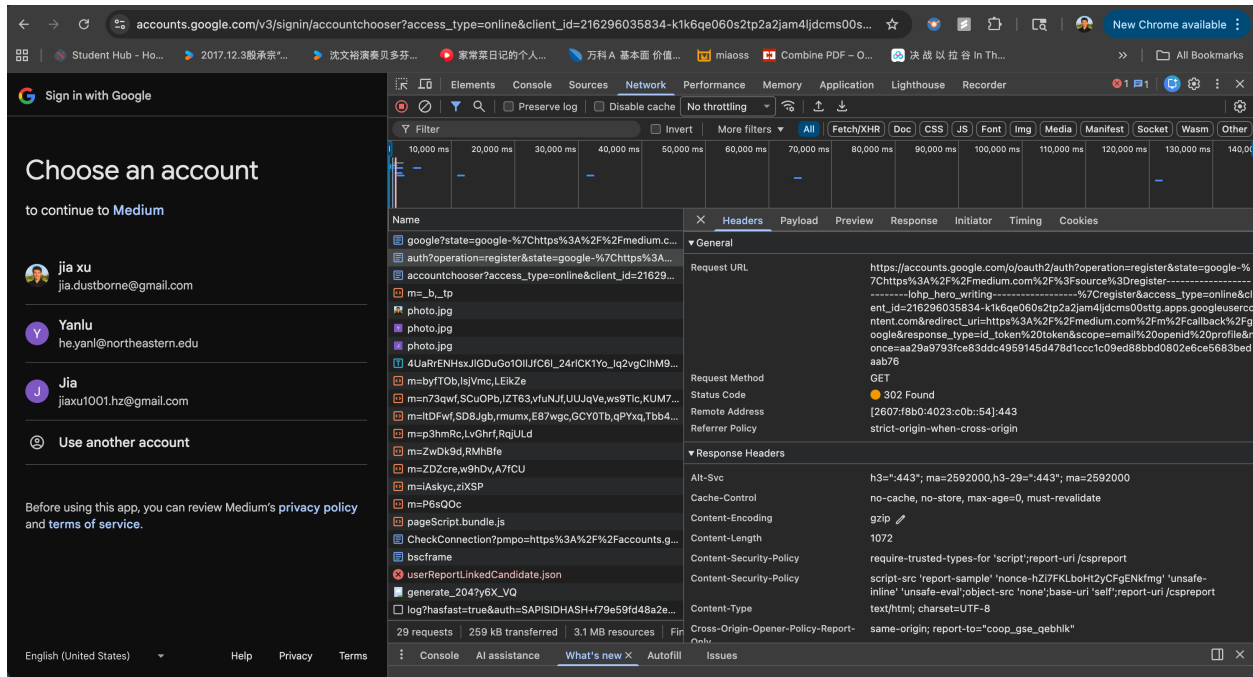


Screenshots



Step-by-Step SSO Flow

1. **Initiation:** You click the "Continue with Google" button. The website redirects your browser to Google's OAuth 2.0 endpoint.
2. **Authentication:** Google asks for your credentials (email/password) or uses your existing session.
3. **Consent:** You agree to share specific info (e.g., email, name).
4. **Redirection (The Code Exchange):** Google redirects you back to the website with a temporary **Authorization Code**.
5. **Token Exchange:** The website's server takes that code and exchanges it with Google for an **ID Token** (containing your identity) and an **Access Token**.

1. The Invisible Handshake (Back-Channel)

In a secure implementation (like Pinterest or Canva), the website doesn't want your browser to ever touch the "Access Token" or "Refresh Token" if it can help it.

- **What you see:** Google sends your browser back to the website with a short-lived `code` in the URL.
- **What you DON'T see:** The website's server takes that `code`, adds its own secret (the `client_secret`), and makes a direct POST request to `https://oauth2.googleapis.com/token`.
- **Why it's hidden:** Since this is a server-to-server call, it never passes through your browser's Network tab. This prevents malicious browser extensions or scripts (XSS) from stealing the master tokens.

- **2. The Final Result: The JWT**
- Once the website's server has confirmed your identity with Google, it creates its own **Session Cookie** or **JWT (JSON Web Token)** to "remember" you.